KẾ HOẠCH ĐIỀU CHỈNH AN TOÀN DỰ ÁN

Website thương mại điện tử Rượu Xứ Nẫu · Bản kế hoạch triển khai tương thích với kiến trúc hiện tại

Mã tài liệu	CR-PLAN-01
Phiên bản	1.1 (đã đối chiếu mã nguồn và đặc tả nghiệp vụ)
Ngày lập	14/10/2026
Phạm vi	11 yêu cầu thay đổi (CR-01 → CR-11), triển khai theo migration tiến, API thật và feature flag để không phá vỡ luồng hiện hành

1. Mục đích và phạm vi

Tài liệu này chuẩn hóa 11 yêu cầu thay đổi theo trạng thái thực tế của dự án: backend Spring Boot đã có nền tảng, Identity/RBAC, Catalog, Media và CMS; frontend Angular vẫn còn dữ liệu và hành vi demo cần thay bằng API thật. Mỗi CR dưới đây nêu rõ phụ thuộc, ranh giới nghiệp vụ và tiêu chí nghiệm thu để việc cập nhật không làm sai luồng bán hàng, thanh toán, tồn kho hoặc phân quyền.

Phạm vi: (A) hoàn thiện tích hợp và bảo mật – CR-01, 02, 03, 07; (B) sửa lỗi/chuẩn hóa giao diện – CR-04, 05, 06; (C) nội dung và chuyển động có dữ liệu thật – CR-08, 09, 10, 11.

Nguyên tắc không phá vỡ hệ thống

- Giữ nguyên hợp đồng /api/v1; thay đổi request/response phải tương thích ngược hoặc phát hành phiên bản mới.
- Không sửa các migration V1–V5 đã chạy. Mọi thay đổi schema dùng migration tiến V6+; MySQL Workbench dùng để quản trị và kiểm tra dữ liệu, không thay thế lịch sử migration của ứng dụng.
- Production chỉ dùng MySQL/API thật, không seed dữ liệu mẫu và không dùng localStorage làm nguồn dữ liệu nghiệp vụ.
- Các chức năng chưa đủ backend hoặc chưa qua UAT phải ẩn bằng feature flag; không để nút có vẻ hoạt động nhưng không có phản hồi.
- Mọi thao tác quyền, đơn hàng, tồn kho, thanh toán, vận chuyển và xuất bản đều được kiểm tra ở backend, có audit và idempotency phù hợp.
- Triển khai qua staging, backup trước migration và có kế hoạch rollback ứng dụng; dữ liệu giao dịch chỉ được sửa bằng migration bù/đối soát, không xóa lịch sử.

2. Bảng tổng hợp yêu cầu thay đổi

Mã	Phân hệ	Nội dung điều chỉnh	Loại thay đổi	Ưu tiên
CR-01	Xác thực & Phân quyền	Nối Angular với RBAC roles/permissions thật; bỏ suy quyền từ email	Hoàn thiện tích hợp / sửa lỗi	Cao
CR-02	Đơn hàng	Tạo/đọc/theo dõi/hủy có điều kiện; không CRUD/xóa đơn tùy ý	Tính năng nghiệp vụ sau M3–M7	Cao
CR-03	Cấu hình nội dung	Quản trị liên hệ, mạng xã hội và cấu hình bản đồ có kiểm soát	Tính năng mới + migration V6+	Trung bình
CR-04	Danh mục sản phẩm – UI	Sửa bộ lọc Dark mode bằng native control trước	Sửa lỗi hiển thị	Cao
CR-05	Footer – UI	SVG chuẩn thương hiệu; URL chính thức lấy từ cấu hình	Cải tiến giao diện	Thấp

Mã	Phân hệ	Nội dung điều chỉnh	Loại thay đổi	Ưu tiên
CR-06	Liên hệ / Bản đồ	Bản đồ tải theo yêu cầu; URL nhúng và URL chỉ đường tách riêng	Cải tiến có kiểm soát	Trung bình
CR-07	Xác thực – UI/UX	Biểu mẫu đúng API, mật khẩu 12–72 byte; bỏ toàn bộ cơ chế demo	Hoàn thiện tích hợp / UI	Cao
CR-08	Trang chủ – Hero	Slide do Admin quản trị, chỉ nội dung đã xuất bản	Tính năng nội dung	Trung bình
CR-09	Trang chủ – Sản phẩm	Băng chuyền dùng Catalog/Inventory API thật, có fallback tĩnh	Cải tiến hiệu ứng	Trung bình
CR-10	Trang chủ – Quy trình	Nội dung 4 bước do Admin quản trị, modal truy cập được	Tính năng nội dung	Trung bình
CR-11	Trang chủ – Tạp chí	Chỉ bài PUBLISHED; băng chuyền an toàn cho accessibility	Cải tiến hiệu ứng	Thấp

Ưu tiên đã được hiệu chỉnh theo rủi ro nghiệp vụ. CR-02 và CR-09 chỉ bật khi các milestone backend phụ thuộc đã nghiệm thu.

3. Đặc tả chi tiết từng yêu cầu

CR-01. Phân quyền người dùng theo vai trò (RBAC)

Phân hệ: **Xác thực & Phân quyền** | Loại: **Hoàn thiện tích hợp / Sửa lỗi** | Ưu tiên: **Cao**

Hiện trạng tương thích

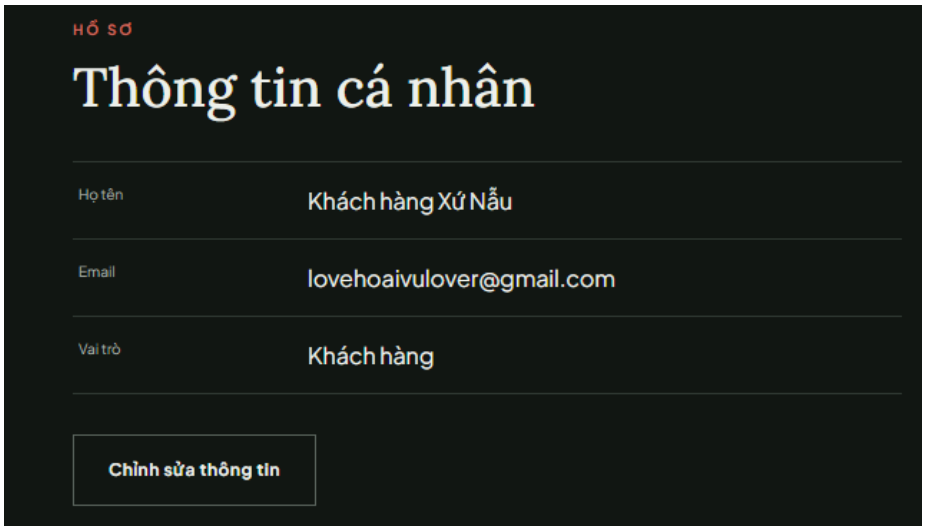
Backend đã có users–roles–permissions dạng nhiều-nhiều, JWT chứa roles/permissions, refresh token rotation và Admin được bootstrap bằng biến môi trường. Frontend vẫn dùng mô hình một trường role, suy Admin từ email chứa chuỗi “admin” và lưu người dùng demo; đây là điểm không tương thích cần xử lý, không phải tạo lại RBAC.

Yêu cầu điều chỉnh an toàn

- Giữ nguyên mô hình nhiều roles/permissions; không thêm cột role đơn lẻ và không sửa migration V2. Angular lấy danh tính từ GET /api/v1/me và kiểm tra permission cho từng màn hình/chức năng.
- Thay Store/AuthGuard/model demo bằng AuthService thật: access token ngắn hạn, refresh cookie HttpOnly, logout/revoke; không lưu mật khẩu, raw refresh token hoặc hồ sơ nghiệp vụ trong localStorage.
- Tài khoản quản trị đã cấu hình phải nhận role ADMIN và đầy đủ permission hiện hành. Mật khẩu chỉ nằm trong secret/environment, tuyệt đối không ghi vào source, migration, log hoặc tài liệu.
- API /admin/** và từng use case tiếp tục kiểm tra permission ở backend. Route guard chỉ hỗ trợ UX; người dùng không có quyền phải nhận 403 kể cả khi gọi API trực tiếp.
- Thay đổi vai trò yêu cầu USER_MANAGE, lưu audit before/after và thu hồi các refresh-token family của tài khoản bị đổi quyền để lần đăng nhập tiếp theo nhận claim mới.

Tiêu chí nghiệm thu

- GET /me của Admin trả role ADMIN và permission thật; trang Hồ sơ/Quản trị hiển thị theo dữ liệu này, không dựa vào chuỗi email.
- Đăng ký mới luôn nhận CUSTOMER; Customer mở URL quản trị được chuyển hướng an toàn và gọi API quản trị nhận 403.
- Không còn ghi chú tài khoản demo, suy quyền phía client hoặc trạng thái đăng nhập giả sau khi tải lại trang.



Hình 1. Ảnh chụp frontend demo cũ: vai trò hiển thị sai; dùng làm bằng chứng cần nối /me, không phải trạng thái backend hiện tại.

CR-02. Quản lý đơn hàng phía khách hàng (CRUD có điều kiện)

Phân hệ: **Đơn hàng / Kho / Thanh toán / Vận chuyển** | Loại: **Tính năng nghiệp vụ sau M3–M7** | Ưu tiên: **Cao**

Hiện trạng tương thích

Order chưa được triển khai đầy đủ ở backend. Vì đơn hàng là chứng từ giao dịch liên quan tồn kho, thanh toán và vận chuyển, yêu cầu "CRUD đầy đủ" sẽ làm mất audit và có thể sai số tiền/tồn kho; phạm vi phải chuyển thành tạo, đọc, theo dõi và yêu cầu hủy theo state machine.

Yêu cầu điều chỉnh an toàn

- Khách hàng chỉ được POST tạo đơn, GET danh sách/chi tiết/timeline đơn của mình và POST yêu cầu hủy khi trạng thái cho phép. Không có DELETE đơn và không cho PATCH tùy ý dòng hàng, tổng tiền, trạng thái thanh toán hoặc trạng thái giao hàng.
- Vòng đời đơn nội bộ: PENDING_PAYMENT (chuyển khoản/VNPay) → PENDING_CONFIRMATION → CONFIRMED → PREPARING → HANDED_OVER → IN_TRANSIT → DELIVERED; nhánh kết thúc CANCELLED. Trạng thái payment và shipment được lưu riêng, không gộp vào order status.
- Khách có thể hủy ở PENDING_PAYMENT, PENDING_CONFIRMATION hoặc CONFIRMED theo ma trận server-side. Từ PREPARING trở đi chỉ nhân sự có ORDER_MANAGE xử lý ngoại lệ; sau HANDED_OVER không cho khách hủy trực tiếp.
- Hủy đơn phải chạy transaction, giải phóng reservation đúng một lần và ghi history/audit. Đơn đã thanh toán không chuyển thẳng sang CANCELLED: phải tạo quy trình refund/đối soát; callback VNPay lặp phải idempotent.
- Order item lưu snapshot SKU/tên/dung tích/giá/giảm giá. Backend tính lại giá, khuyến mãi, phí vận chuyển; dùng Idempotency-Key và optimistic locking để chống double-click/cập nhật đồng thời.
- Khách chỉ đọc đơn của mình; Admin/nhân sự xử lý theo permission. Trạng thái vận chuyển chỉ đổi từ thao tác quản trị hợp lệ hoặc webhook nhà vận chuyển đã xác minh.

Tiêu chí nghiệm thu

- Hai lần tạo đơn với cùng Idempotency-Key chỉ sinh một đơn và một lần giữ tồn; không có đường đi làm tồn âm.
- Customer A không thể đọc/hủy đơn của Customer B; mọi chuyển trạng thái sai trả ORDER_INVALID_STATE (409).
- Hủy trước ngưỡng cho phép giải phóng tồn đúng một lần; đơn đã thanh toán đi qua refund/đối soát, không xóa hoặc sửa lịch sử giao dịch.
- Giao diện ẩn/khóa thao tác không hợp lệ và luôn hiển thị lý do; backend vẫn là lớp quyết định cuối cùng.

CR-03. Quản trị thông tin liên hệ trên trang quản trị

Phân hệ: **Cấu hình nội dung hệ thống** | Loại: **Tính năng mới + migration tiến** | Ưu tiên: **Trung bình**

Hiện trạng tương thích

Thông tin liên hệ/footer đang hard-code và còn dữ liệu demo. CMS bài viết đã tồn tại nhưng chưa có kho cấu hình có kiểu dữ liệu dành cho thông tin doanh nghiệp và nội dung trang chủ.

Yêu cầu điều chỉnh an toàn

- Bổ sung bảng/cấu trúc site_settings có khóa định danh, kiểu dữ liệu, version và audit bằng migration V6+; không sửa V1–V5. Tạo permission SITE_CONTENT_MANAGE và gán bằng migration tham chiếu cho role ADMIN.
- Admin quản trị điện thoại, email, địa chỉ, giờ làm việc, URL mạng xã hội, URL chỉ đường và URL nhúng bản đồ. Public API chỉ trả các trường đã công bố; cập nhật dùng validation, optimistic locking và cache invalidation.
- URL iframe phải tách khỏi URL chỉ đường, chỉ chấp nhận HTTPS và allowlist tên miền Google Maps; cấu hình CSP frame-src tương ứng để ngăn chèn nội dung tùy ý.
- MySQL Workbench dùng để xem/quản trị MySQL thật; ứng dụng vẫn phải lưu lịch sử schema bằng migration tiến trong repository để staging/production nhất quán và có thể tái lập.

Tiêu chí nghiệm thu

- Cập nhật một lần trong Admin được phản ánh nhất quán ở trang Liên hệ, footer và các khu vực dùng chung sau khi cache được làm mới.
- Dữ liệu sai định dạng, URL ngoài allowlist hoặc cập nhật version cũ bị từ chối; thao tác có audit actor/before/after/traceId.
- Không còn chuỗi “Địa chỉ demo” hoặc giá trị hard-code trong build production.



Hình 2. Khối liên hệ hiện tại cần chuyển sang site settings có validation và audit.

CR-04. Giao diện Dark mode – thành phần bộ lọc sản phẩm

Phân hệ: **Danh mục sản phẩm – UI** | Loại: **Sửa lỗi hiển thị** | Ưu tiên: **Cao**

Hiện trạng tương thích

Select “Dòng rượu” không kế thừa đúng bảng màu Dark mode. Đây là lỗi trình bày; không nên đổi sang custom listbox ngay nếu native select có thể đáp ứng vì custom control làm tăng rủi ro bàn phím và trình đọc màn hình.

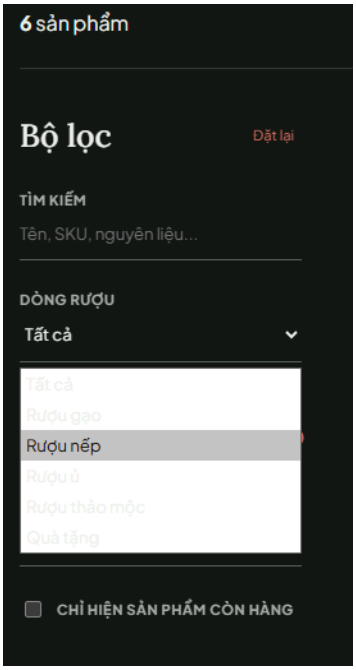
Yêu cầu điều chỉnh an toàn

- Ưu tiên native select với color-scheme, design token cho nền/chữ/viền/focus và stylesheet riêng theo trình duyệt. Chỉ dùng component listbox đã được kiểm thử accessibility nếu native control vẫn không đạt yêu cầu sản phẩm.
- Đồng bộ input, checkbox, nút Đặt lại, option disabled/selected, validation và focus-visible ở cả Light/Dark mode.

- Danh mục/bộ lọc lấy từ Catalog API thật; trạng thái loading, empty, error và retry phải có phản hồi rõ ràng, không dùng mock làm nguồn production.

Tiêu chí nghiệm thu

- Tương phản văn bản và focus indicator đạt WCAG 2.1 AA; thao tác được bằng bàn phím, touch và trình đọc màn hình.
- Đạt trên Chrome, Edge, Safari, Firefox và các mốc 320/375/768/1024/1440 px; không còn nền trắng chói trong Dark mode.



Hình 3. Lỗi tương phản của native select trong Dark mode cần được kiểm thử đa trình duyệt.

CR-05. Chân trang – nhận diện thương hiệu biểu tượng mạng xã hội

Phân hệ: **Footer – UI / Cấu hình nội dung** | Loại: **Cải tiến giao diện** | Ưu tiên: **Thấp**

Hiện trạng tương thích

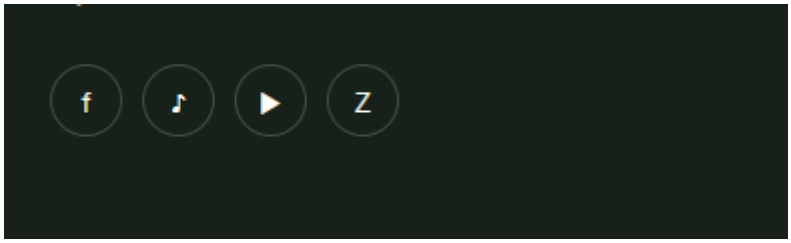
Biểu tượng hiện tại là ký tự minh họa và URL chưa được quản trị tập trung. Việc chỉ thay icon mà vẫn hard-code liên kết sẽ tạo thêm nợ kỹ thuật.

Yêu cầu điều chỉnh an toàn

- Dùng SVG chính thức/được cấp phép, giữ đúng tỷ lệ và vùng an toàn thương hiệu; icon có tên truy cập, focus-visible và vùng chạm tối thiểu 44×44 px.
- URL Facebook/TikTok/YouTube/Zalo lấy từ cấu hình CR-03, chỉ hiển thị nền tảng có URL hợp lệ; mở tab mới với rel="noopener noreferrer".
- Không hard-code màu/URL trong nhiều component; dùng token và một component dùng chung để footer/contact không lệch dữ liệu.

Tiêu chí nghiệm thu

- Mỗi liên kết mở đúng trang chính thức, không có icon chết hoặc URL placeholder trên production.
- Hiển thị rõ ở Light/Dark mode, retina, zoom 200%; hỗ trợ chuột, bàn phím và cảm ứng.



Hình 4. Biểu tượng mạng xã hội hiện tại; URL/hiển thị mới phải lấy từ cấu hình đã duyệt.

CR-06. Chân trang – nhúng bản đồ Google Maps trực quan

Phân hệ: **Trang Liên hệ / Footer** | Loại: **Tích hợp bên thứ ba có kiểm soát** | Ưu tiên: **Trung bình**

Hiện trạng tương thích

Liên kết maps.app.goo.gl là URL chỉ đường rút gọn, không phải URL iframe. Nhúng iframe ở mọi footer còn làm tăng tải mạng trên toàn website và có thể ảnh hưởng Core Web Vitals/quyền riêng tư.

Yêu cầu điều chỉnh an toàn

- Lưu riêng directionsUrl và embedUrl trong CR-03. Không đưa short URL trực tiếp vào iframe; chỉ Admin có SITE_CONTENT_MANAGE được cấu hình URL đã qua allowlist.
- Hiển thị bản đồ đầy đủ ở trang Liên hệ. Ở footer dùng địa chỉ + nút Chỉ đường hoặc ảnh xem trước/click-to-load; iframe chỉ khởi tạo sau thao tác người dùng và loading="lazy".
- Có fallback khi Google Maps bị chặn/lỗi: vẫn thấy địa chỉ và mở được URL chỉ đường. CSP chỉ cho phép đúng domain cần thiết.

Tiêu chí nghiệm thu

- Vị trí, địa chỉ và nút chỉ đường dùng cùng nguồn cấu hình; URL sai/ngoài allowlist bị chặn.
- Không có iframe tải trên mọi trang trước tương tác; Lighthouse/Core Web Vitals không suy giảm vượt ngân sách đã chốt.

CR-07. Biểu mẫu đăng ký / đăng nhập – chuẩn hóa nghiệp vụ và căn chỉnh giao diện

Phân hệ: **Xác thực – UI/UX** | Loại: **Hoàn thiện tích hợp / Cải tiến UI** | Ưu tiên: **Cao**

Hiện trạng tương thích

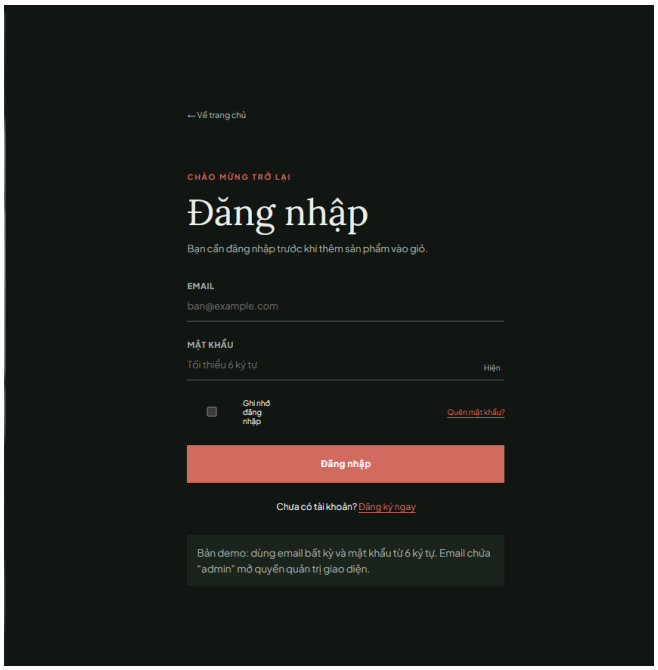
Backend đăng ký hiện nhận fullName, email, password và ageConfirmed; phone là trường hồ sơ tùy chọn. Chính sách mật khẩu thật là 12–72 byte, có chữ hoa, chữ thường và chữ số. Frontend vẫn còn thông điệp 6 ký tự, đăng nhập demo và cơ chế suy quyền từ email.

Yêu cầu điều chỉnh an toàn

- Biểu mẫu đăng ký bám đúng API hiện hành: Họ tên, Email, Mật khẩu, Xác nhận mật khẩu (chỉ kiểm tra client) và xác nhận đủ 18 tuổi/điều khoản. Phone là tùy chọn cập nhật hồ sơ; nếu muốn bắt buộc sau này phải triển khai field nullable trước rồi mới siết validation ở phiên bản sau.
- Helper text nêu đúng chính sách 12–72 byte, có chữ hoa, chữ thường và số; backend trả Problem Details/field errors là nguồn quyết định. Không log hoặc lưu mật khẩu.
- Loại bỏ login demo, ghi chú email chứa “admin” và dữ liệu user localStorage. Sau đăng nhập dùng access token + refresh cookie HttpOnly, tải GET /me và quay lại returnUrl hợp lệ.
- Chỉ hiển thị “Ghi nhớ đăng nhập” khi backend hỗ trợ TTL refresh tương ứng; checkbox không được biến thành lưu token trong localStorage. Căn hàng tùy chọn và Quên mật khẩu ở mọi kích thước.

Tiêu chí nghiệm thu

- UI và backend thống nhất validation; lỗi 400/401/423/429 hiển thị thông báo đúng ngữ cảnh và không làm mất dữ liệu không nhạy cảm người dùng đã nhập.
- Guest thao tác giỏ/checkout được đưa đến đăng nhập và quay lại đúng trang; người dùng chưa đăng nhập không thể thêm giỏ.
- Điều hướng bàn phím, label, autocomplete, aria-describedby và focus lỗi đạt WCAG; không còn hành vi demo sau build production.



Hình 5. Biểu mẫu demo cũ; phải bỏ suy quyền từ email và chuẩn hóa theo API thật.

CR-08. Banner trang chủ – trình chiếu tự động (hero slider) với hiệu ứng chuyển cảnh hiện đại

Phân hệ: **Trang chủ – Hero / CMS** | Loại: **Tính năng nội dung** | Ưu tiên: **Trung bình**

Hiện trạng tương thích

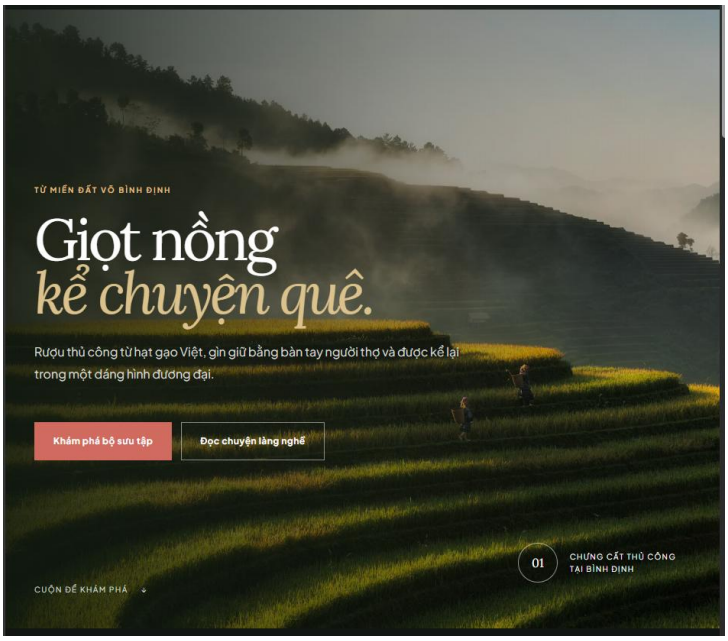
Hero đang là nội dung tĩnh. Nếu chỉ hard-code nhiều ảnh vào Angular, Admin không thể vận hành và production tiếp tục phụ thuộc dữ liệu demo.

Yêu cầu điều chỉnh an toàn

- Bổ sung nội dung hero do Admin quản trị bằng SITE_CONTENT_MANAGE: ảnh desktop/mobile từ Media, alt text, tiêu đề, mô tả, CTA nội bộ, thứ tự, thời gian hiệu lực và trạng thái DRAFT/PUBLISHED/ARCHIVED.
- Public API chỉ trả slide PUBLISHED còn hiệu lực, tối đa 5 slide. Không có dữ liệu thì dùng một fallback thương hiệu đã duyệt hoặc ẩn carousel; không kéo ảnh nóng (hotlink) từ website ngoài ở production.
- Autoplay mặc định 6 giây, chuyển cảnh 1.2–1.6 giây; có prev/next, chỉ báo, swipe, pause khi hover/focus/tab ẩn và đảm bảo focus không tự di chuyển.
- Dùng responsive image, WebP/AVIF, preload có chọn lọc và chỉ animate transform/opacity. prefers-reduced-motion chuyển sang fade ngắn hoặc slide tĩnh.

Tiêu chí nghiệm thu

- Admin tạo/duyệt/xuất bản slide; nội dung nháp không xuất hiện công khai và mọi thay đổi có audit.
- Không có CLS/khoảng trắng; đạt ngân sách LCP và hoạt động với bàn phím, touch, zoom 200% và chế độ giảm chuyển động.



Hình 6. Hero hiện tại; slide mới phải là nội dung đã xuất bản từ Media/CMS.

CR-09. Danh sách sản phẩm nổi bật – băng chuyền tự động chạy vô hạn liền mạch

Phân hệ: **Trang chủ – Catalog / Inventory** | Loại: **Cải tiến hiệu ứng sau dữ liệu thật** | Ưu tiên: **Trung bình**

Hiện trạng tương thích

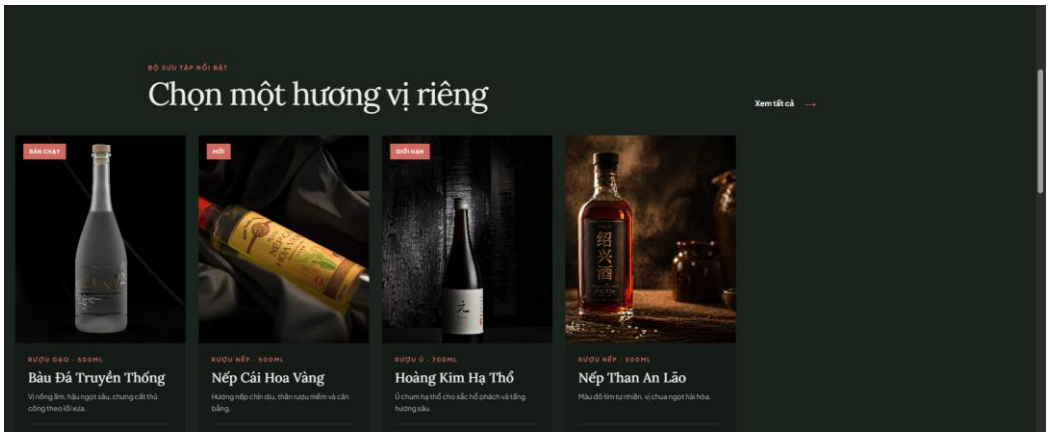
Dải sản phẩm đang dùng dữ liệu phía client và có khoảng trống khi lặp. Chuyển động chỉ có ý nghĩa sau khi Catalog API được nối và tồn khả dụng được cung cấp từ Inventory.

Yêu cầu điều chỉnh an toàn

- Nguồn dữ liệu là GET /api/v1/products với bộ lọc featured/active; không import mock. Chỉ hiển thị sản phẩm/danh mục đang hoạt động; trạng thái còn hàng lấy từ backend sau M3.
- Nếu số thẻ không đủ lấp hai lần viewport, hiển thị grid/carousel thủ công thay vì nhân bản vô hạn. Bản sao trực quan phải aria-hidden, không có duplicate id và không nhận focus; thẻ gốc vẫn mở đúng sản phẩm.
- Tốc độ là cấu hình; mặc định phải → trái, pause khi hover/focus/touch, hỗ trợ swipe. prefers-reduced-motion hiển thị danh sách tĩnh có thể cuộn ngang.
- Có loading/skeleton/empty/error/retry; khi API lỗi không thay bằng doanh thu/sản phẩm demo. Feature flag giữ section ẩn cho tới khi backend contract ổn định.

Tiêu chí nghiệm thu

- Chạy liên tục 10 phút ở 360/768/1280/1920 px không khoảng trống, giật, duplicate focus hoặc lỗi console.
- Sản phẩm ngừng bán không xuất hiện sau cache invalidation; giá và tồn hiển thị đúng dữ liệu backend.



Hình 7. Khoảng trống ở dải sản phẩm hiện tại; dữ liệu production phải lấy từ Catalog/Inventory API.

CR-10. Quy trình sản xuất 4 bước – thẻ tương tác dạng "gói" (pack card)

Phân hệ: **Trang chủ – Nội dung quy trình** | Loại: **Tính năng nội dung** | Ưu tiên: **Trung bình**

Hiện trạng tương thích

Bốn bước đang là nội dung tĩnh. Chưa có nguồn nội dung chính thức cho mô tả dài, thời gian và hình ảnh; không được dùng nội dung/ảnh tạm làm dữ liệu production.

Yêu cầu điều chỉnh an toàn

- Quản trị 4 bước bằng site content hoặc CMS có thứ tự, tiêu đề, mô tả ngắn/dài, thời gian, ảnh Media, alt text và trạng thái xuất bản; public chỉ đọc bản PUBLISHED.
- Thẻ pack card có hover/focus nhẹ bằng transform, không làm xô bố cục. Trên touch không phụ thuộc hover và không dùng chuyển động nảy quá mạnh gây khó chịu.
- Chi tiết mở bằng dialog/panel đạt chuẩn: focus trap, trả focus về thẻ, Esc/nút X/ngoài vùng theo thiết kế, prev/next có nhãn và trạng thái disabled rõ ràng.

Tiêu chí nghiệm thu

- Mỗi thẻ mở đúng dữ liệu từ API; bản nháp/thiếu ảnh không xuất hiện hoặc dùng fallback nội bộ đã duyệt.
- Hoạt động với chuột, bàn phím, touch và trình đọc màn hình; prefers-reduced-motion tắt hiệu ứng nảy.



Hình 8. Khối quy trình hiện tại; nội dung chi tiết cần được Admin xuất bản trước khi mở tương tác.

CR-11. Chuyên mục "Tạp chí xứ Nẫu" – băng chuyền chạy ngược chiều

Phân hệ: **Trang chủ – CMS bài viết** | Loại: **Cải tiến hiệu ứng** | Ưu tiên: **Thấp**

Hiện trạng tương thích

CMS backend đã có workflow bài viết; frontend vẫn cần bỏ dữ liệu mẫu và chỉ lấy bài công khai. Yêu cầu bài viết do Admin/nhân sự có quyền xuất bản phải được giữ nguyên.

Yêu cầu điều chỉnh an toàn

- Nguồn là GET /api/v1/articles; endpoint công khai chỉ trả PUBLISHED còn hiệu lực. Editor có thể tạo/sửa/gửi duyệt, chỉ Publisher/Admin có ARTICLE_MANAGE phù hợp mới xuất bản/gỡ bài.
- Băng chuyền mặc định trái → phải, tốc độ chậm hơn sản phẩm, pause khi hover/focus/touch. Khi ít bài hoặc reduced motion, dùng grid tĩnh; không nhân bản phần tử tương tác theo cách tạo duplicate focus/id.
- Ảnh/tiêu đề/slug lấy từ CMS và Media; lỗi API hiển thị empty/error state, không tự thay bằng bài demo. Card luôn điều hướng đúng slug đã xuất bản.

Tiêu chí nghiệm thu

- Bài DRAFT/IN_REVIEW/ARCHIVED không thể truy cập từ public API hoặc URL trực tiếp; chỉ PUBLISHED được hiển thị.
- Không có khoảng hở, CLS, lỗi console hoặc phần tử focus trùng; chuyển động tắt đúng theo prefers-reduced-motion.



Hình 9. Lưới bài hiện tại; băng chuyền mới chỉ dùng bài PUBLISHED từ CMS.

4. Quyết định tương thích và đầu vào còn thiếu

Các quyết định dưới đây được dùng làm baseline. Hạng mục thiếu dữ liệu chính thức phải giữ feature flag tắt; không đưa placeholder vào production.

#	Quyết định / đầu vào	Baseline an toàn
1	RBAC và tài khoản quản trị – CR-01	Giữ roles/permissions hiện có; frontend lấy /me, không suy quyền từ email.
2	Chính sách mật khẩu – CR-07	12–72 byte, có chữ hoa, chữ thường và số; backend là nguồn quyết định.
3	Vòng đời và quyền hủy đơn – CR-02	Không CRUD/xóa đơn; hủy theo state matrix và quy trình refund/giải phóng tồn.
4	Chu kỳ/chuyển động – CR-08/09/11	Hero 6 giây; sản phẩm phải→trái; bài viết trái→phải; reduced motion dùng dạng tĩnh/fade.
5	Địa chỉ và bản đồ – CR-03/06	Cần địa chỉ chính thức + embedUrl; short link hiện có chỉ dùng làm directionsUrl.
6	Nội dung 4 bước và hero – CR-08/10	Cần nội dung/ảnh đã duyệt; tạm ẩn bằng feature flag nếu chưa có, không seed demo production.
7	Mạng xã hội – CR-05	Cần URL chính thức; chỉ hiển thị nền tảng có cấu hình hợp lệ.
8	Quản lý hình ảnh	Development có thể dùng placeholder nội bộ; production dùng Media/CDN do dự án kiểm soát, không hotlink tùy ý.

5. Lộ trình triển khai không gián đoạn

Giai đoạn	Hạng mục	Ghi chú phụ thuộc
Giai đoạn 0 Baseline & hợp đồng	Đóng băng contract /api/v1; backup MySQL; kiểm thử hồi quy Identity, Catalog, CMS	Không sửa V1–V5; lập feature flag và ma trận permission/state transition.
Giai đoạn 1 Identity & UI an toàn	CR-01, CR-04, CR-07	Nối auth thật trước; bỏ local/mock; sửa UI nhưng không đổi hợp đồng backend ngoài kế hoạch.
Giai đoạn 2 Site content	CR-03, CR-05, CR-06, CR-08, CR-10, CR-11	Migration V6+ + SITE_CONTENT_MANAGE; Admin publish trước, public read sau.
Giai đoạn 3 Commerce	M3 Inventory → M4 Cart → M5 Order/Bank → M6 VNPay → M7 Shipping; sau đó CR-02/CR-09	Không bật order/product availability trước khi reservation, payment IPN/refund và shipping adapter qua UAT.
Giai đoạn 4 Hardening & phát hành	E2E, security, accessibility, performance, đối soát và UAT	Canary/feature flag, smoke test sau deploy, theo dõi và rollback ứng dụng khi vi phạm ngưỡng.

6. Yêu cầu phi chức năng áp dụng chung

- Responsive tại 320, 375, 768, 1024 và 1440 px; zoom 200%; Chrome, Edge, Safari, Firefox và thiết bị thật.
- WCAG 2.1 AA: tương phản, focus visible, điều hướng bàn phím, semantics/ARIA đúng vai trò và prefers-reduced-motion.
- Production không dùng mock, data seed hoặc localStorage làm nguồn nghiệp vụ. Dữ liệu sản phẩm, bài viết, người dùng, đơn và dashboard đều đến từ API/MySQL thật.
- MySQL dùng UTC, DECIMAL cho tiền, optimistic locking/atomic update cho tồn; migration tiến V6+ chạy được từ database hiện tại và database rỗng.
- Auth/checkout/payment/refund/shipment có rate limit, ownership, idempotency, audit, trace ID và Problem Details; secrets chỉ qua environment/secret manager.
- VNPay: backend ký URL, IPN server-to-server là nguồn xác nhận, kiểm checksum/merchant/reference/amount và xử lý callback lặp đúng một lần. Return URL chỉ hiển thị kết quả.
- Shipping dùng adapter nhà cung cấp thật, map trạng thái nội bộ, verify webhook và chống tạo trùng vận đơn; lỗi provider không làm mất hoặc tự đổi đơn.
- Ảnh dùng Media/object storage/CDN, có alt/fallback/size phù hợp; ngân sách Core Web Vitals được đo trước và sau thay đổi.
- Không phát hành khi còn lỗi P0/P1 hoặc P2 trên luồng đăng nhập, giỏ, checkout, kho, thanh toán, quyền; không còn nút chết, lỗi console hay API error chưa xử lý.

7. Điều kiện phát hành, giám sát và rollback

Mỗi giai đoạn chỉ được bật trên production khi hoàn tất nghiệm thu tương ứng. Mục tiêu chất lượng là không còn lỗi nghiêm trọng đã biết và có khả năng phát hiện/khôi phục; không dùng cam kết tuyệt đối “không bao giờ có bug” thay cho kiểm thử và giám sát.

- Trước deploy: backup có kiểm chứng restore, chụp version schema/app, chạy migration trên bản sao staging và lưu báo cáo smoke test.
- Sau deploy: health check, metrics, structured log/trace, tỷ lệ lỗi API, callback VNPay, inventory reservation và shipping webhook phải được giám sát/cảnh báo.
- Rollback ưu tiên tắt feature flag hoặc quay lại phiên bản ứng dụng tương thích schema. Không rollback bằng cách xóa đơn/payment/inventory transaction; dùng migration bù và đối soát có audit.
- UAT bắt buộc gồm quyền Admin/Customer/guest, đăng nhập/refresh/logout, Catalog/CMS, quantity 0 xóa dòng giỏ, checkout COD/chuyển khoản/VNPay, duplicate IPN, refund và trạng thái vận chuyển.
- Biên bản nghiệm thu ghi rõ version frontend/backend/schema, dữ liệu test, kết quả, lỗi tồn đọng và người phê duyệt trước khi mở feature flag cho người dùng cuối.